

Actividad 01 — Análisis y Planificación del Pentest

Caso: Aurora Market | Hacker Women Council · Ethical Hacking

Nombre completo: María Sofía Martín

1. Objetivo del pentest

Objetivos concretos que tendrá la evaluación de seguridad de Aurora Market:

- Identificar vulnerabilidades de control de acceso que permitan a un usuario visualizar información perteneciente a otra cuenta, en relación directa con el incidente reportado.
- Evaluar la robustez del mecanismo de autenticación de la plataforma (gestión de sesiones, políticas de contraseñas y protección ante ataques de fuerza bruta).
- Determinar la presencia de vulnerabilidades del tipo OWASP Top 10 (inyección, XSS, exposición de datos sensibles) en los flujos de carrito, checkout y gestión de pedidos.

2. Alcance

Sí se evaluará:

- Aplicación web de Aurora Market (frontend y backend).
- Formularios de registro, inicio de sesión y recuperación de cuenta.
- Módulo de carrito de compras y checkout.
- Panel de cuenta del cliente y panel de administración del personal.
- API expuesta por la aplicación web, si corresponde.

Fuera del alcance:

- Redes sociales de la empresa.
- Equipos personales, correos y cuentas de los empleados.
- Proveedores externos y cualquier sistema fuera de la aplicación web autorizada.

3. Autorización y condiciones

Permisos requeridos:

- Autorización formal y por escrito otorgada por Aurora Market.
- Definición de cuentas de prueba e IPs autorizadas para realizar las pruebas.
- Ventana horaria acordada, correspondiente a los períodos de menor actividad.
- Canal de comunicación directo para reportar hallazgos críticos de forma inmediata.

Condiciones acordadas:

- No realizar ataques ni pruebas fuera del alcance definido.
- No ejecutar acciones que puedan interrumpir el funcionamiento de la plataforma.
- No exfiltrar ni modificar información real de clientes.
- Mantener confidencialidad de los hallazgos hasta la entrega del informe final.
- Utilizar cuentas de prueba en lugar de cuentas de clientes reales siempre que sea posible.

4. Tipo de pentest

Tipo de pentest elegido: **Gray-box**

Justificación: el equipo cuenta con información parcial de la plataforma (existencia de aplicación web, base de datos, mecanismos de autenticación y distintos tipos de usuario), pero no conoce en detalle la arquitectura interna, el código fuente ni las configuraciones del sistema. Este enfoque simula el comportamiento de un atacante con cierto conocimiento —como un usuario registrado— sin llegar a ser un insider con acceso total, lo cual es coherente con el origen del incidente que motivó la evaluación (reportado por un usuario común de la plataforma).

5. Planificación

Elemento	Detalle
Objetivos	Identificar vulnerabilidades de control de acceso vinculadas al incidente reportado, evaluar la robustez de la autenticación y detectar vulnerabilidades OWASP Top 10 en carrito, checkout y pedidos.
Alcance	Aplicación web de Aurora Market (frontend, backend, login, carrito, checkout, cuenta de cliente y panel de administración). Quedan fuera redes sociales, equipos y correos del personal, y proveedores externos.
Permisos y condiciones	Autorización formal por escrito, cuentas e IPs de prueba habilitadas, ventana horaria de baja actividad, canal directo para reportar hallazgos críticos, y prohibición de interrumpir el servicio o afectar datos reales de clientes.
Metodología a utilizar	OWASP Testing Guide (OTG), por estar orientada específicamente a aplicaciones web y cubrir autenticación, sesiones y control de acceso.
Recopilación de información previa	Reconocimiento pasivo del sitio público, mapeo de funcionalidades visibles (login, catálogo, carrito, cuenta) e identificación de tecnologías mediante headers, cookies y mensajes de error.
Recursos necesarios	Cuenta(s) de prueba, proxy interceptor (Burp Suite / OWASP ZAP), entorno aislado de pruebas y documentación para registrar hallazgos.
Programación del pentest	Semana 1: reconocimiento. Semana 2: análisis de vulnerabilidades. Semana 3: explotación controlada. Semana 4: elaboración del informe. Ejecución en horarios de baja actividad.

6. Fases del pentest aplicadas a Aurora Market

Reconocimiento: Releva la estructura pública de la aplicación (páginas, formularios, tecnologías utilizadas) sin realizar interacciones intrusivas.

Análisis de vulnerabilidades: Evalúa el login y la gestión de sesiones, verifica si la modificación de identificadores en la URL permite acceder a pedidos o datos de otro usuario (vinculado directamente al incidente reportado) y revisa fallas de validación en el carrito y checkout.

Explotación: Confirma de forma controlada y no destructiva las vulnerabilidades identificadas, por ejemplo demostrando el acceso indebido mediante una cuenta de prueba, sin afectar datos reales.

Post-explotación: Evalúa el impacto real del hallazgo: qué datos podrían verse comprometidos y si el problema afecta a un usuario puntual o a la totalidad de la base de clientes.

Informe: Documenta cada hallazgo indicando severidad, evidencia recabada y recomendaciones concretas para el equipo de desarrollo de Aurora Market.

7. Investigación de metodología

Metodología elegida: **OWASP Testing Guide (OTG)**

¿Por qué sería útil para este proyecto? Se trata de una metodología orientada específicamente a la evaluación de seguridad de aplicaciones web, lo cual coincide exactamente con el alcance autorizado del proyecto. Además, contempla de manera detallada pruebas de autenticación, gestión de sesiones y control de acceso, aspectos directamente relacionados con el incidente que dio origen a esta evaluación. Como alternativa, podría complementarse con PTES (Penetration Testing Execution Standard) para dar cobertura al proceso completo del proyecto, más allá de la aplicación web en sí.

Recuerda: antes de comenzar cualquier prueba técnica es fundamental tener claros los objetivos, el alcance y las condiciones del pentest.